

Chapitre 5

La communication des risques — corrigés

Corrigé

Jaouad Madkour

Faculté d'Économie et de Gestion de Tanger
Exercices et corrigés · Risque opérationnel et résilience

1 Corrigés des exercices du chapitre

Corrigé de l'exercice 1 — Destinataires du reporting, strates et règles d'un reporting utile

- (a) Le comité des risques du conseil se distingue par sa fonction de « supervision stratégique » : il ne gère aucune activité, il oriente. Le comité de direction se distingue par ses « arbitrages opérationnels » : il décide de l'allocation des ressources et de la priorisation des actions correctives. La fonction centrale de gestion du risque opérationnel se distingue par sa « coordination et agrégation » : elle ne produit pas l'information de terrain, elle la consolide et l'homogénéise entre lignes d'activité. Les responsables métiers et champions du risque se distinguent par leur « gestion quotidienne » : ils sont au contact direct et permanent du risque, avant toute agrégation. Le comité d'audit se distingue par son « assurance indépendante » : contrairement aux quatre premières catégories, il n'est pas partie prenante de la gestion du risque mais en vérifie, de l'extérieur, la qualité. Les destinataires externes – régulateurs et public – se distinguent enfin en ce qu'ils ne participent à aucun titre à la gestion interne du risque : leur besoin est celui d'une divulgation formelle et comparable, non d'un outil de pilotage.
- (b) Cette relation inverse est une nécessité, et non un choix esthétique de présentation, car le conseil d'administration a pour rôle de décider des orientations stratégiques, une tâche qui exige de repérer les signaux significatifs parmi le bruit plutôt que de les noyer dans un volume d'information ingérable à ce niveau de responsabilité. Si le conseil recevait le même volume d'information détaillée que le niveau opérationnel, il perdrait sa capacité même à « décider » : soit il consacrerait un temps disproportionné à trier lui-même l'information pertinente – une tâche qui n'est pas la sienne et pour laquelle il n'est pas outillé –, soit il finirait, plus vraisemblablement, par ignorer l'essentiel de ce volume faute de pouvoir le traiter, ce qui reviendrait à ne recevoir, de fait, aucune information utile à la décision malgré un volume nominal considérable.
- (c) La condition qui déclenche le passage à la troisième strate n'est pas la gravité de l'incident pris isolément, mais son caractère *révéléateur d'une faiblesse structurelle de contrôle affectant l'appétit pour le risque de l'organisation*. Un incident isolé, même grave, reste par définition un événement ponctuel dont on ignore, sans agrégation ni analyse, s'il traduit un problème systémique ou un aléa localisé ; il relève donc du niveau surveiller ou, au mieux, agir. Ce n'est que lorsque l'agrégation de plusieurs incidents similaires révèle un motif récurrent qui dépasse les seuils d'appétit pour le risque définis par le conseil lui-même que l'information change de nature : elle cesse de porter sur un cas particulier à corriger et porte désormais sur la validité même du dispositif de contrôle et de l'appétit pour le risque que le conseil a la responsabilité de superviser – justifiant que seule la *conclusion* de cette analyse, et non chaque occurrence qui l'a alimentée, lui soit transmise.
- (d) Un tableau détaillé d'indicateurs opérationnels violerait la première règle (coût-bénéfice) car le temps que le conseil devrait consacrer à en extraire lui-même l'information pertinente excéderait largement le bénéfice qu'il pourrait en tirer à son niveau de responsabilité. Il violerait la deuxième règle (finalité claire) car un tel tableau, conçu pour le pilotage quotidien d'une équipe opérationnelle, ne répond à aucune question stratégique précise que le conseil aurait à trancher – il n'est pas « aligné sur une finalité » propre au niveau conseil. Il violerait enfin la troisième règle (aide à la décision) car la plupart de ses lignes, prises isolément, ne changeraient jamais rien à l'orientation stratégique que le conseil doit fixer : conformément au cours, un tel reporting serait alors « superflu, quelle que soit sa qualité technique », à ce niveau précis de destinataire – bien qu'il reste indispensable, sans aucune modification, au niveau opérationnel pour lequel il a été conçu.

Corrigé de l'exercice 2 — Les sept composantes d'un reporting complet

- (a) Le top 10, la cartographie thermique et le registre des risques portent sur la même information de base – l'ensemble des risques opérationnels identifiés et évalués de l'organisation –, présentée à des niveaux de détail décroissants selon le destinataire visé. Le registre des risques en est la forme la plus détaillée, « la référence exhaustive pour les équipes opérationnelles », correspondant à la

strate surveiller de l'exercice 1(b). La cartographie thermique en offre une synthèse visuelle par probabilité et impact, un niveau d'agrégation intermédiaire proche de la strate agir. Le top 10 en constitue la forme la plus condensée, en « hiérarchis[ant] explicitement » les risques les plus significatifs plutôt que de les présenter « comme une liste plate », un format directement calibré pour la strate décider et son conseil d'administration. Les trois composantes ne sont donc pas des informations différentes mais un même socle de connaissance du risque, filtré à trois degrés de granularité croissants en descendant vers le terrain.

- (b) Le cours conclut que la communication doit être « aussi événementielle » car le mécanisme de seuil rouge, tel que décrit, « déclenche une escalade automatique au comité des risques, indépendamment du calendrier normal de reporting » : l'information ne remonte pas parce qu'une date de reporting périodique est arrivée, mais parce qu'un fait précis – le franchissement d'un seuil – vient de se produire, à un moment qui n'a par construction aucun lien avec le calendrier trimestriel habituel. C'est cette indépendance au calendrier, et non la nature de l'indicateur lui-même, qui rend la communication événementielle : un même KRI rouge franchi en milieu de trimestre déclenche la même escalade immédiate qu'un franchissement constaté le jour même du reporting périodique, la logique de déclenchement étant celle du fait, non celle du temps écoulé.
- (c) Le problème (issue) précède toute perte : c'est une faiblesse de contrôle ou de processus *identifiée avant sa matérialisation*, typiquement par l'audit ou une auto-évaluation. L'incident, à l'inverse, est la matérialisation *effective* d'un risque, qu'il ait ou non causé une perte financière : il s'est réellement produit. Le quasi-incident se situe entre les deux par sa nature (un événement réel s'est produit, comme pour l'incident) mais rejoint le problème par son absence de préjudice effectif : il aurait pu causer une perte mais ne l'a, par chance ou grâce à un contrôle de rattrapage, pas fait. Ce qui rend structurellement la remontée d'un quasi-incident plus difficile que celle d'un incident avéré est précisément l'absence de conséquence visible qui la motiverait spontanément : un incident avec perte s'impose de lui-même à l'attention (une perte comptable doit être expliquée), tandis qu'un quasi-incident, n'ayant rien coûté en apparence, ne laisse aucune trace obligatoire et dépend entièrement de la bonne volonté de celui qui l'a observé – volonté que seule une culture du risque sans blâme injustifié peut susciter de façon fiable.
- (d) Un plan d'action correctif en retard constitue un problème de gouvernance distinct du risque opérationnel initial car il révèle une défaillance d'un ordre différent : non plus la vulnérabilité que le plan visait à corriger (dont la persistance était, à l'origine, prévue et budgétée jusqu'à l'échéance du plan), mais l'incapacité de l'organisation à honorer ses propres engagements de remédiation dans le délai qu'elle s'était elle-même fixé – une défaillance de *discipline d'exécution* qui existerait même si, par chance, le risque sous-jacent ne se matérialisait jamais entretemps. C'est pourquoi le cours la qualifie de problème « aussi grave » que le risque lui-même : elle mine la crédibilité de l'ensemble du dispositif de gestion du risque, bien au-delà du seul risque concerné par ce plan d'action précis. La veille prospective crée quant à elle une boucle entre reporting et identification car elle est la seule des sept composantes dont la matière première n'est pas déjà connue de l'organisation (pertes passées, RCSA déjà réalisées, contrôles déjà en place) mais porte sur des menaces *encore extérieures* à son inventaire de risques : en la faisant remonter comme composante du reporting, l'organisation ne se contente pas de rendre compte d'un risque déjà géré, elle transmet une matière brute destinée à enrichir, en amont, l'inventaire du chapitre 2 – alors que les six autres composantes ne font que rendre compte, en aval, de risques déjà identifiés et déjà en cours de gestion.

Corrigé de l'exercice 3 — Les défis statistiques du reporting, l'agrégation qualitative et l'assurance externe

- (a) Le rapport est $66,6/0,4 = 166,5$: les pertes supérieures à 10 millions d'euros concentrent, en sévérité, 166,5 fois la part qu'elles représentent en nombre d'occurrences. Ce rapport justifie à lui seul la conclusion du cours car il démontre qu'une moyenne calculée sur l'ensemble des pertes serait presque entièrement déterminée par une poignée d'événements (0,4 % du nombre total) plutôt que par la masse des pertes courantes : une moyenne des pertes ne représenterait alors ni

la réalité de la très grande majorité des occurrences (les 99,6 % restants, de sévérité individuelle bien plus faible), ni celle d'une période typique sans événement extrême – elle ne serait, par construction, la moyenne d'*aucune situation réellement représentative*.

- (b) Un reporting qui communiquerait uniquement la perte opérationnelle moyenne de l'année violerait directement cette recommandation à un double titre : il retiendrait un « indicateur de tendance centrale » là où le cours demande de « privilégier les distributions, les percentiles et les événements extrêmes », et il omettrait « une mention de sa dispersion sous-jacente », laissant croire à tort que ce chiffre unique représente une réalité homogène. À la place ou en complément, un tel reporting devrait présenter, au minimum, plusieurs percentiles de la distribution des pertes (médiane, 95^e, 99^e, 99,9^e) et une mention explicite des événements extrêmes survenus dans l'année, afin de donner au destinataire une idée de l'écart entre le cas typique et le cas extrême que la seule moyenne dissimulerait.
- (c) La méthode du pire cas plausible serait moins compatible avec l'objectif de vue unique et comparable car elle consiste, par définition, à retenir « le scénario le plus défavorable raisonnablement envisageable » pour chaque risque considéré isolément – un chiffre qui n'est comparable à aucun autre puisqu'il ne correspond, par construction, à aucune probabilité homogène d'un risque à l'autre (le pire cas plausible d'un risque très improbable et celui d'un risque fréquent n'ont pas la même signification statistique). La conversion en équivalent monétaire, à l'inverse, produit pour chaque risque qualitatif une même grandeur – une perte annuelle attendue, homogène à celle des risques mesurés quantitativement (pertes historiques, VaR) – ce qui permet précisément de les juxtaposer sur une même échelle et une même cartographie sans rupture de sens entre les cases.
- (d) L'assurance combinée et le Pilier 3 poursuivent, chacun à son niveau, le même objectif de cohérence d'une vision unique du risque : l'assurance combinée l'atteint en interne en coordonnant les travaux des trois lignes de défense pour « fournir au conseil une vision unique et cohérente [...], plutôt que trois rapports disjoints et parfois contradictoires », tandis que le Pilier 3 l'atteint en externe en imposant une divulgation structurée et standardisée – gouvernance, historique des pertes, indicateur d'exploitation – destinée à donner au marché une vision cohérente et comparable de l'exposition de l'établissement. Ce même objectif ne devient un « enjeu de crédibilité et de réputation » que pour le Pilier 3 car sa vision, contrairement à celle de l'assurance combinée, est rendue publique et jugée par des tiers – investisseurs, analystes, marché – qui n'ont accès à aucune autre source d'information sur le dispositif interne de l'établissement : toute incohérence ou faiblesse qui y transparaît, comme l'illustre le cas Credit Suisse, engage directement la confiance du marché envers l'établissement, alors qu'une incohérence détectée en interne par l'assurance combinée reste, elle, un problème de gouvernance corrigible avant toute exposition publique.

2 Corrigé de l'exercice cumulatif

Corrigé de l'exercice 4 — La communication des risques à la lumière des quatre chapitres précédents

- (a) Le KCI et le suivi des plans d'action de ce chapitre forment bien, ensemble, le canal de reporting des résultats du chapitre 4 : un KCI mesurant « la robustesse d'un contrôle donné » n'a de sens que s'il repose sur un test effectivement réalisé – auto-certification, examen documentaire, observation ou reperformance –, et c'est la reperformance, « la forme de test la plus exigeante » selon le chapitre 4, qui produit l'évidence la plus fiable pour alimenter ce KCI; de même, un plan d'action correctif suivi jusqu'à l'objectif zéro de ce chapitre n'existe que parce qu'un test du chapitre 4 a d'abord révélé une faiblesse de contrôle à corriger. Le chapitre 4 définit ainsi la rigueur de la mesure sans indiquer comment son résultat circule ensuite dans l'organisation; ce chapitre comble précisément ce manque en fournissant le KCI comme vecteur de communication du résultat du test, et le suivi des plans d'action comme vecteur de

communication de sa remédiation. Le cas Knight Capital, résultant en partie de « l'absence de hiérarchisation des alertes, et [de] l'absence de procédure d'urgence », est exactement le scénario que l'objectif zéro sur les plans d'action en retard et les seuils rouges d'escalade automatique de ce chapitre visent à empêcher : un dispositif de reporting qui hiérarchise ses alertes (par un code couleur) et qui déclenche une escalade immédiate et automatique dès qu'un seuil critique est franchi – indépendamment du calendrier normal – élimine précisément la double défaillance de communication qui a permis à Knight Capital de perdre 460 millions de dollars en 45 minutes sans qu'aucune procédure d'urgence ne soit activée à temps.

- (b) Ce chapitre ajoute au chapitre 3 exactement la dimension de destinataire, de fréquence et de conséquence de gouvernance que le chapitre 3 ne traitait pas : le chapitre 3 définit le trio KPI/KRI/KCI et le code couleur de la carte de chaleur comme des outils de *mesure*, sans préciser à qui, quand ni avec quelle suite ils doivent être communiqués ; ce chapitre répond à ces trois questions en attachant au même trio d'indicateurs et au même code couleur un destinataire (le comité des risques pour un seuil rouge, le second niveau de contrôle pour un seuil orange), une fréquence (trimestrielle, ou événementielle en cas de franchissement critique) et une conséquence de gouvernance précise (investigation, escalade automatique). De la même façon, la mise en garde de ce chapitre contre les moyennes n'est pas une observation statistique indépendante : elle découle directement de la queue épaisse de la sévérité que le chapitre 3 avait déjà établie par la LDA (« distribution continue, asymétrique et à queue épaisse ») et par le calcul du capital économique au « 99,9^e centile », un centile extrême qui n'aurait de sens à calculer que si la distribution sous-jacente possède effectivement cette queue épaisse. Le chiffre ORX cité par ce chapitre (« 0,4 % du nombre d'occurrences [...] 66,6 % de la sévérité totale ») est ainsi une illustration empirique, au niveau de l'industrie, de la même propriété statistique que le chapitre 3 avait déjà modélisée analytiquement pour une ligne d'activité : sans cette propriété déjà démontrée au chapitre 3, la recommandation de ce chapitre de « privilégier les distributions [et] les percentiles » plutôt que la moyenne serait une préférence stylistique sans fondement quantitatif.
- (c) Le chapitre 2 avait effectivement déjà situé le top 10 comme un produit de son propre inventaire des risques, en précisant qu'il est « rapporté au moins trimestriellement au comité exécutif » – une fréquence et un destinataire que ce chapitre reprend sans les modifier lorsqu'il le replace parmi ses sept composantes de reporting et ses trois strates de destinataires (le comité exécutif correspondant ici à la strate agir de l'exercice 1(b)). Sur les quasi-incidents, ce chapitre ne fait qu'ajouter un qualificatif (« source d'apprentissage [...] souvent sous-exploitée ») à la définition et à la condition culturelle déjà posées, mot pour mot, par le chapitre 2 – il ne propose aucun mécanisme de reporting concret (fréquence, destinataire, seuil) spécifique aux quasi-incidents, comparable à celui qu'il détaille pour les KRI ou pour les plans d'action : le chapitre 2 identifiait la difficulté (l'absence de culture sans blâme comme condition de remontée), et ce chapitre se contente de la répéter sous une autre formulation sans lui apporter, contrairement au cas des KRI, d'appareil de gouvernance dédié. Le chapitre 2 (par le PESTLE) et ce chapitre (par le reporting des risques émergents) décrivent bien une boucle fermée et non une relation à sens unique : le PESTLE du chapitre 2 produit les risques émergents qui, une fois identifiés, deviennent la matière de la septième composante du reporting de ce chapitre ; mais ce même reporting, une fois communiqué aux destinataires appropriés, redevient à son tour un intrant du prochain exercice d'identification du chapitre 2 – par exemple lorsqu'un risque émergent signalé au conseil déclenche une nouvelle analyse de scénarios ou une mise à jour de la taxonomie. En ce sens précis, et pour cette septième composante uniquement, le reporting de ce chapitre n'est pas la dernière étape apparente du cycle mais aussi, en boucle, l'un des points d'entrée de sa première étape.
- (d) Les trois lignes de défense du chapitre 1 se superposent terme à terme aux six catégories de destinataires de ce chapitre : la première ligne (« le personnel opérationnel et commercial ») correspond aux responsables métiers et champions du risque de ce chapitre ; la deuxième ligne (le CORE, « la fonction indépendante de gestion du risque opérationnel ») correspond à la fonction centrale de gestion du risque opérationnel de ce chapitre, ainsi qu'au comité de direction pour ses arbitrages opérationnels ; la troisième ligne (« l'audit interne, qui fournit une assurance indépendante ») correspond très directement au comité d'audit de ce chapitre. Le comité des

risques du conseil et les destinataires externes n'appartiennent, quant à eux, à aucune des trois lignes : ils se situent au-dessus d'elles (supervision ultime) ou en dehors du périmètre interne (régulateurs, public). L'assurance combinée de ce chapitre répond précisément à la tension déjà implicite au chapitre 1 entre l'indépendance de chaque ligne – condition de la valeur propre de son assurance, en particulier celle de la troisième ligne vis-à-vis des deux premières – et la cohérence de la vision d'ensemble : coordonner les trois lignes sans fusionner leurs rôles respectifs permet de préserver cette indépendance tout en évitant que le conseil ne reçoive « trois rapports disjoints et parfois contradictoires », chacun défendant implicitement le point de vue de sa propre ligne. Enfin, les seuils vert/orange/rouge du tableau de bord de KRI de ce chapitre donnent un contenu opérationnel et quotidiennement surveillable aux « seuils de fréquence et de sévérité des incidents tolérés » que le chapitre 1 attachait à l'appétit pour le risque sans en préciser le mécanisme de suivi ; et le Pilier 3 de ce chapitre transforme, de façon symétrique, le principe déclaratif de transparence de la RPSMOR du chapitre 1 (« publication de l'approche et des expositions ») en une obligation de publication périodique effective, avec un contenu précis (qualitatif, pertes historiques, indicateur d'exploitation) que le chapitre 1 ne faisait que nommer parmi ses douze principes sans en détailler la forme.

3 Corrigé des applications en sciences économiques

Corrigé de l'exercice 5 — Un tableau de bord de KRI trimestriel, ses seuils d'alerte, et l'effet de la queue épaisse des pertes, chiffrés

- (a) KRI 1 (145, entre 100 et 180) : **ORANGE**. KRI 2 (18 %, entre 10 et 20) : **ORANGE**. KRI 3 (7, au-delà de 6) : **ROUGE**. KRI 4 (1,5 h, en dessous de 2) : **VERT**. KRI 5 (12, en dessous de 15) : **VERT**. KRI 6 (5, au-delà de 2) : **ROUGE**. Le trimestre compte donc 2 KRI en zone verte, 2 en zone orange (KRI 1 et KRI 2) et 2 en zone rouge (KRI 3 et KRI 6). Selon le cours, chacun des deux KRI orange déclenche « une investigation par le second niveau de contrôle », tandis que chacun des deux KRI rouge déclenche « une escalade automatique au comité des risques, indépendamment du calendrier normal de reporting » : ce trimestre compte ainsi 2 investigations de second niveau et 2 escalades automatiques au comité des risques.
- (b) La part des 9 événements extrêmes dans le nombre total d'événements est $9/2500 = 0,36\%$, très proche du chiffre de l'industrie cité par le cours (0,4 %). Leur part dans la sévérité totale est $225/340 = 66,18\%$, également très proche du chiffre de l'industrie (66,6 %) : la banque de cet exercice reproduit donc, sur ses propres données, une concentration presque identique à celle observée sur l'ensemble de l'industrie par la base ORX. La perte moyenne par événement sur l'ensemble des 2 500 événements est $340/2500 = 0,136$ M€, soit **136 000 €**. La perte moyenne par événement sur les 2 491 événements restants (hors les 9 événements extrêmes, dont la sévérité cumulée à retirer est $340 - 225 = 115$ M€) est $115/2491 = 0,046166$ M€, soit environ **46 166 €**. Le rapport entre les deux moyennes est $136000/46166 = 2,95$: la moyenne calculée sur l'ensemble des événements est ainsi presque **trois fois supérieure** à la perte typique effectivement subie par la quasi-totalité des événements (les 2 491 non extrêmes) – la preuve chiffrée directe qu'« il n'y a pas de moyennes pertinentes en risque opérationnel » : la moyenne globale ne représente ni le cas typique (trop élevée par rapport à lui) ni le cas extrême (trop faible par rapport à lui), mais un artefact arithmétique dominé par 9 observations sur 2 500.
- (c) Le rapport entre le capital économique et la médiane est $890/300 = 2,97$: le 99,9^e centile de la distribution simulée est près de trois fois plus élevé que sa médiane. Le rapport entre ce même capital économique et la sévérité effectivement observée cette année (340 M€, une réalisation proche de la médiane simulée) est $890/340 = 2,62$. Le cours recommande de communiquer ces centiles plutôt qu'un seul chiffre agrégé de perte moyenne car une moyenne (ou même une médiane isolée) ne renseignerait en rien le conseil sur l'ampleur du pire scénario plausible que l'établissement doit être en mesure d'absorber : seule la progression complète des centiles – ici de 300 à 890 M€ entre la médiane et le 99,9^e centile, soit un quasi-triplement – donne au destinataire une idée fidèle de la dispersion et de l'épaisseur de la queue de la distribution, information qu'un

chiffre unique de tendance centrale ne pourrait jamais transmettre.

- (d) Avec 2 franchissements de seuil rouge par trimestre en moyenne et 4 trimestres par an, le nombre total d'escalades automatiques sur l'année est $2 \times 4 = 8$. Le rapport entre ce nombre d'escalades et le nombre de cycles de reporting trimestriels réguliers (4 par an) est $8/4 = 2,0$: l'établissement déclenche ainsi, en moyenne, deux fois plus d'escalades événementielles au fil de l'année que de cycles de reporting périodiques programmés. Ce résultat illustre concrètement que la communication du risque « ne doit pas être purement périodique mais aussi événementielle » : si le comité des risques ne recevait de l'information que lors des 4 rendez-vous trimestriels prévus au calendrier, il manquerait la majorité des signaux d'alerte critique de l'année, ceux-ci survenant, par construction, à des moments indépendants de ce calendrier.

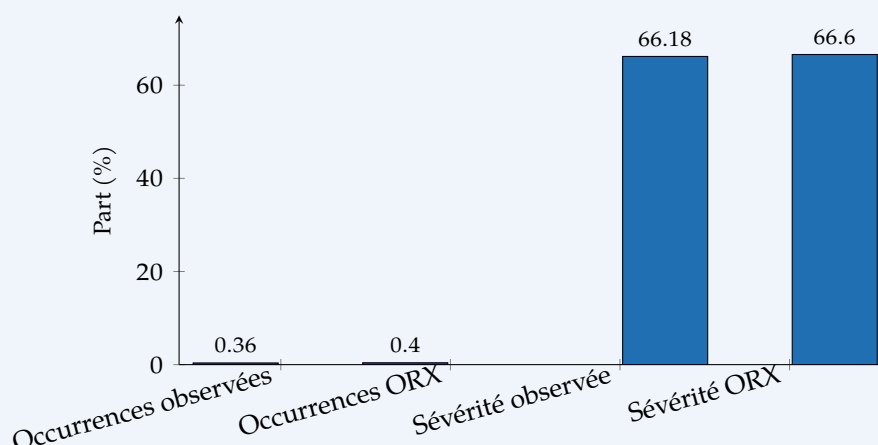


FIG. 1 : Comparaison, sur les données de la banque de l'exercice, de la part des événements extrêmes (> 10 M€) dans le nombre d'occurrences et dans la sévérité totale, avec les chiffres de l'industrie (base ORX) cités par le cours — exercice 5.

Corrigé de l'exercice 6 — Cartographie thermique agrégée : conversion en équivalent monétaire, pire cas plausible et perte de granularité, chiffrés

- (a) L'équivalent monétaire de R4 (fréquence niveau 4 = 45 %, sévérité niveau 3 = 2,5 M€) est $0,45 \times 2,5 = 1,125$ M€. Celui de R5 (fréquence niveau 2 = 8 %, sévérité niveau 5 = 10,0 M€) est $0,08 \times 10,0 = 0,800$ M€. Celui de R6 (fréquence niveau 3 = 20 %, sévérité niveau 4 = 5,0 M€) est $0,20 \times 5,0 = 1,000$ M€. Le classement décroissant des six risques est : R1 (4,200 M€) > R2 (2,800 M€) > R3 (1,500 M€) > R4 (1,125 M€) > R6 (1,000 M€) > R5 (0,800 M€). La méthode utilisée pour R4, R5 et R6 est la **conversion en équivalent monétaire**, qui « attribu[e] une valeur financière estimée à un risque qualitatif » – ici le produit de la fréquence annuelle et de la sévérité issues du barème interne validé.
- (b) Le total agrégé des six équivalents monétaires est $4,2 + 2,8 + 1,5 + 1,125 + 1,000 + 0,800 = 11,425$ M€. La part de R1 dans ce total est $4,2/11,425 = 36,76$ %. La part cumulée des trois risques mesurés quantitativement ($R1+R2+R3 = 8,500$ M€) est $8,500/11,425 = 74,40$ %, contre $2,925/11,425 = 25,60$ % pour les trois risques qualitatifs convertis ($R4+R5+R6 = 2,925$ M€). Cette concentration ne relève **pas** du même phénomène statistique que celui des données ORX : le chiffre ORX du cours (0,4 % des événements individuels concentrant 66,6 % de leur sévérité cumulée) décrit l'asymétrie de la queue d'une distribution de pertes *au sein d'une même catégorie de risque*, alors que la concentration observée ici (74,40 % du total réparti sur seulement 3 des 6 catégories de risque) décrit une hétérogénéité *entre catégories distinctes* sur une cartographie synthétique annuelle – un phénomène de nature différente, quoique tout aussi révélateur d'une répartition inégale du risque, qu'il ne faut pas confondre avec la queue épaisse des pertes individuelles au sein d'une même catégorie.
- (c) Le rapport entre le pire cas plausible de R5 (18,0 M€) et son équivalent monétaire pondéré par

la fréquence calculé au (a) (0,800 M€) est $18,0/0,800 = 22,5$: le pire cas plausible représente plus de vingt-deux fois l'équivalent monétaire moyen affiché sur la cartographie. Le cours suggère que cette approche peut être plus informative pour un risque à queue épaisse comme le risque cyber car l'équivalent monétaire pondéré par la fréquence – construit comme une espérance – lisse précisément ce que le conseil a le plus besoin de connaître pour un tel risque : la possibilité d'un événement rare mais massivement destructeur, qu'une fréquence de seulement 8 % réduit à un chiffre d'apparence modeste (0,800 M€) sur la cartographie, alors que le scénario réellement redouté (18,0 M€) resterait invisible derrière cette moyenne pondérée. Elle se prête cependant moins bien à une vue unique et comparable car un pire cas plausible n'est, par construction, homogène à aucune probabilité commune d'un risque à l'autre, contrairement à l'équivalent monétaire qui reste comparable terme à terme sur l'ensemble de la cartographie.

- (d) La moyenne des huit scores (2,3,3,4,3,2,4,3) est $(2+3+3+4+3+2+4+3)/8 = 24/8 = 3,0$, ce qui confirme bien le niveau 3 utilisé au (a). L'écart-type de cette série est **0,71** (les scores individuels s'échelonnant de 2 à 4 autour de cette moyenne). Le chiffre unique de 1,125 M€ affiché pour R4 sur la cartographie dissimule entièrement cette dispersion : il ne renseigne en rien le conseil sur le fait qu'un quart des participants de l'atelier (deux sur huit) ont jugé la sévérité de ce risque à un niveau nettement supérieur (niveau 4, soit 5,0 M€ de sévérité) à celui finalement retenu, ni que deux autres l'ont jugée nettement inférieure (niveau 2, soit 1,2 M€). C'est un exemple concret de la « perte de granularité que le conseil accepte en échange de la lisibilité » : la cartographie thermique offre au conseil un chiffre unique, lisible et comparable aux cinq autres risques, au prix de l'effacement complet du désaccord et de l'incertitude qui existaient pourtant, de façon documentée, au sein même de l'atelier RCSA qui l'a produit.

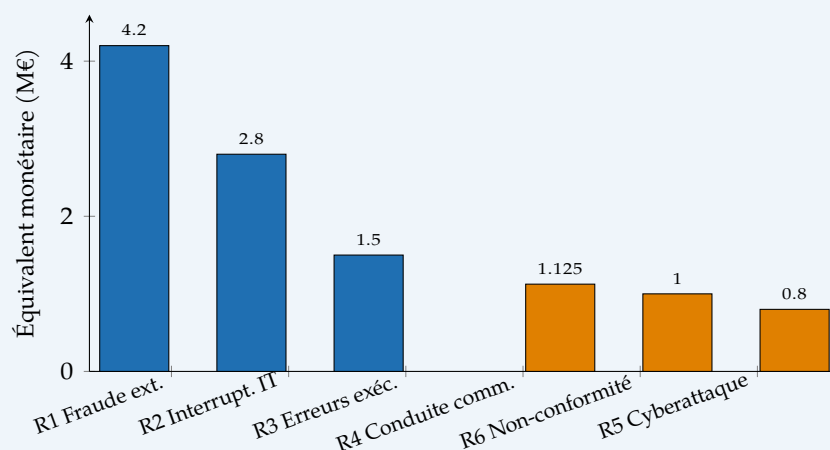


FIG. 2 : Classement décroissant des six catégories de risque de la cartographie thermique agrégée : les trois risques mesurés quantitativement (en bleu) et les trois risques qualitatifs convertis en équivalent monétaire par RCSA (en orange) — exercice 6.